

Manual 17 — Implementação Controlada do NIST Privacy Framework

Edição controlada pt-BR

****Ordem da série:**** 17

****Linha de base estável:**** NIST Privacy Framework 1.0

****Identidade da fonte congelada:**** `80d8569aeeb57d209293f8fe1423be43efa36cdb`

****Decisão sobre o estado da fonte:**** PF 1.1 permanece como Initial Public Draft / publicação final futura; o material do rascunho 1.1 é usado somente como inteligência de mudança não normativa.

****Estado de publicação:**** fonte controlada localizada; ainda não renderizada, vinculada por hash, armazenada de forma durável ou publicada.

Uso e limites

Este é um guia de implementação independente. Não reproduz texto protegido de terceiros, não cria direitos de certificação e não converte orientação voluntária do NIST em requisitos legais. Cada organização deve determinar separadamente as leis de privacidade, contratos, requisitos regulatórios, obrigações setoriais e deveres jurisdicionais aplicáveis.

O modelo de implementação usa o NIST Privacy Framework 1.0 publicado como linha de base determinística e organiza a governança em torno das funções Identify-P, Govern-P, Control-P, Communicate-P e Protect-P, utilizando linguagem de implementação original.

Modelo de evidência controlada

Cada controle de privacidade implementado deve ser rastreável por: autoridade ou justificativa; responsável; procedimento repetível; gatilho/frequência; objeto de evidência; local da evidência; método de revisão/teste; caminho de exceção/remediação; e gatilho de reavaliação.

Caminhos de implementação:

- ****Essencial:**** governança e evidência mínimas e repetíveis.
- ****Estruturado:**** modelo operacional multifuncional documentado com métricas, testes e escalonamento.
- ****Avançado:**** evidência automatizada, análise quantitativa, monitoramento contínuo e asseguarção integrada.

Capítulo 1 — Propósito do Programa de Privacidade e Modelo Operacional

Definir carta do programa, escopo, direitos de decisão, calendário operacional anual, limites de escalonamento e relatórios gerenciais. Responsável: líder executivo de privacidade.

Evidência: carta aprovada, RACI, calendário, registro de decisões e aprovações de

governança. Testar anualmente se todas as atividades exigidas têm responsável, periodicidade, repositório e caminho de escalonamento. Reavaliar após mudanças regulatórias, organizacionais, tecnológicas, de produto ou incidentes relevantes.

Capítulo 2 — Contexto Organizacional e Partes Interessadas

Identificar linhas de negócio, jurisdições, indivíduos, reguladores, clientes, força de trabalho, fornecedores, objetivos estratégicos e dependências que moldam o risco de privacidade. Responsável: área de privacidade com jurídico e risco corporativo. Evidência: registro de contexto, inventário de partes interessadas, matriz jurisdicional e premissas de risco. Revisar anualmente e após entrada em mercado, aquisição, reestruturação, questionamento regulatório ou alteração contratual relevante.

Capítulo 3 — Escopo e Limites

Definir entidades, sistemas, dados, produtos, locais, processos e terceiros cobertos; documentar exclusões e dependências. Responsável: líder de privacidade com arquitetura e responsáveis de negócio. Evidência: declaração de escopo, diagramas de limite, registro de exclusões e mapa de dependências. Conciliar o escopo com inventários de ativos, fornecedores, aplicações e tratamentos.

Capítulo 4 — Governança e Responsabilização da Liderança

Estabelecer política de privacidade, apetite a risco, fóruns de governança, limites de reporte, decisões de recursos, escalonamento e revisão gerencial. Responsável: órgão executivo de governança. Evidência: regimento do comitê, atas, decisões, relatórios de risco e aprovações de recursos. Verificar se riscos significativos e ações vencidas chegam à administração com decisão documentada.

Capítulo 5 — Papéis, Responsabilidades e Segregação

Manter RACI e autoridades delegadas para privacidade, jurídico, segurança, engenharia, produto, governança de dados, RH, compras, resposta a incidentes, auditoria e executivos. Evidência: responsabilidades de função, aprovações delegadas e regras de segregação. Testar decisões amostradas para confirmar aprovação autorizada e revisão independente quando exigida.

Capítulo 6 — Inventário de Tratamentos e Mapeamento de Dados

Manter registros atuais de coleta, geração, uso, compartilhamento, armazenamento, transformação, arquivamento e exclusão de dados pessoais. Registrar categorias, indivíduos, finalidades, fontes, destinatários, locais, retenção, justificativa, classificação e

relações com operadores. Evidência: inventário de tratamentos, fluxos de dados, atestações de responsáveis e relatórios de conciliação. Conciliar continuamente com revisão formal anual.

Capítulo 7 — Metodologia de Avaliação de Risco de Privacidade

Definir cenários de risco, indivíduos afetados, ações problemáticas sobre dados, dimensões de consequência, premissas de probabilidade, força dos controles, risco residual, incerteza, autoridade de aceitação e períodos de reavaliação. Evidência: metodologia aprovada, avaliações, premissas e decisões de risco residual. Reexecutar amostras para validar consistência de pontuação e qualidade da evidência.

Capítulo 8 — Avaliação de Impacto e Revisão de Alto Risco

Triar tratamentos novos ou alterados para revisão reforçada; documentar propósito, necessidade, fluxos, populações, cenários de risco, salvaguardas, alternativas, risco residual, aprovações e condições de monitoramento. Evidência: registro de triagem, avaliação de impacto, aprovação, condições e comprovação de implementação. Tratamento de alto risco não aprovado é escalado para restrição, redesenho ou decisão formal de risco.

Capítulo 9 — Políticas, Padrões e Procedimentos

Manter uma hierarquia controlada que vincule política de privacidade a padrões, procedimentos, responsáveis, aprovações, ciclos de revisão e evidências. Evidência: biblioteca documental controlada, histórico de versões, aprovações, confirmações e arquivo de retirada. Testar requisitos de política amostrados contra procedimentos operacionais e evidências.

Capítulo 10 — Privacidade desde a Concepção e Engenharia

Integrar pontos de controle de privacidade em arquitetura, produto, software, dados e ciclos de mudança. Avaliar minimização, separação, acesso, retenção, transparência, controles do usuário, telemetria e testabilidade. Evidência: registro de design de privacidade, revisão de arquitetura, análise de risco, decisões, testes e condições de aprovação. Reavaliar diante de mudanças materiais de funcionalidade, integração, modelo ou arquitetura.

Capítulo 11 — Especificação de Finalidade e Limitação de Uso

Registrar finalidades aprovadas de tratamento e governar usos secundários materiais. Evidência: registro de finalidades, aprovações de casos de uso, avaliações de mudança, registro de decisões e vínculo com avisos. Comparar o uso real de sistemas e análises com

as finalidades aprovadas. Usos sem suporte exigem suspensão, redução, exclusão ou reavaliação.

Capítulo 12 — Minimização de Dados e Controles de Coleta

Exigir justificativa para atributos coletados, questionar campos opcionais, eliminar cópias redundantes e usar agregação ou desidentificação quando apropriado. Evidência: justificativas de elementos de dados, revisões de esquema, formulários de coleta e registros de limpeza. Testar sistemas amostrados para detectar campos sem finalidade atual ou justificativa de retenção.

Capítulo 13 — Consentimento, Preferências e Escolha Individual

Quando mecanismos de consentimento ou preferência forem usados, definir apresentação, captura, prova, retirada, propagação e tratamento de exceções. Evidência: desenho de consentimento, registros de preferências, versões de linguagem, logs de propagação e testes de retirada. Executar testes ponta a ponta para confirmar que preferências alteradas chegam aos sistemas posteriores dentro dos níveis de serviço definidos.

Capítulo 14 — Transparência e Comunicações de Privacidade

Manter avisos de privacidade e comunicações internas precisos e adequados ao público, alinhados ao tratamento real. Evidência: inventário de avisos, mapeamento tratamento-aviso, aprovações, histórico de versões, prova de publicação e revisão de acessibilidade/legibilidade. Corrigir rapidamente inexactidões materiais e avaliar indivíduos e obrigações afetados.

Capítulo 15 — Operação de Solicitações dos Indivíduos

Operar fluxos consistentes de recebimento, verificação de identidade, roteamento, busca, revisão, resposta, exceção e evidência para solicitações de privacidade quando legalmente exigidas ou voluntariamente oferecidas. Evidência: tickets, registro de verificação, evidência de busca, pacote de resposta, aprovação de exceção e métricas de SLA. Testar solicitações amostradas quanto a completude, autorização, tempestividade e execução posterior.

Capítulo 16 — Qualidade e Exatidão dos Dados

Definir onde a exatidão afeta materialmente indivíduos, decisões, serviços ou obrigações; estabelecer processos de correção e propagação. Evidência: regras de qualidade, logs de validação, correções e mapeamentos de fonte de verdade. Revisar inexactidões recorrentes e causas-raiz; reavaliar quando novos usos decisórios ou integrações de dados forem introduzidos.

Capítulo 17 — Retenção, Arquivamento e Exclusão

Manter cronogramas de retenção vinculados a justificativa documentada; implementar arquivamento e exclusão em produção, backup, analytics e terceiros quando viável. Evidência: cronograma de retenção, configuração de sistemas, logs de exclusão, exceções e retenções legais. Testar repositórios de dados amostrados contra períodos aprovados.

Capítulo 18 — Identidade, Acesso e Tratamento Privilegiado

Aplicar acesso baseado em função, menor privilégio, autenticação, controles de acesso privilegiado, revisão periódica e revogação tempestiva a sistemas com dados pessoais. Evidência: matrizes de acesso, aprovações, logs, recertificações e registros de sessões privilegiadas. Testar amostras de admissão/movimentação/desligamento e acesso privilegiado; corrigir acessos excessivos.

Capítulo 19 — Coordenação entre Segurança e Privacidade

Integrar requisitos de privacidade com risco de segurança da informação, vulnerabilidades, logs, monitoramento, criptografia, resposta a incidentes e engenharia segura. Evidência: mapeamentos conjuntos de controles, registros de risco, arquitetura de segurança, resultados de monitoramento e tickets de remediação. Verificar se os controles de segurança tratam cenários de risco de privacidade e não assumir que segurança, isoladamente, resolve o risco de privacidade.

Capítulo 20 — Governança de Terceiros e Operadores

Avaliar fornecedores e parceiros antes da contratação e durante toda a relação. Registrar finalidade, escopo de dados, jurisdição, controles de segurança/privacidade, obrigações contratuais, suboperadores, incidentes, retenção, devolução/exclusão e saída. Evidência: due diligence, contratos, avaliações de risco, monitoramento, remediação e prova de desligamento.

Capítulo 21 — Nuvem e Responsabilidade Compartilhada

Documentar responsabilidades de privacidade entre cliente, provedor de nuvem, SaaS e suboperadores. Mapear locais dos dados, acesso administrativo, responsabilidade por criptografia/chaves, logs, retenção, exclusão, notificação de incidentes e propriedade de configuração. Evidência: matriz de responsabilidade compartilhada, diagramas de arquitetura, atestações do provedor e revisões de configuração.

Capítulo 22 — Movimentação Transfronteiriça e Jurisdicional de Dados

Manter visibilidade de armazenamento, acesso remoto, transferências, divulgações posteriores e restrições jurisdicionais relevantes. Responsável: privacidade/jurídico com arquitetura e compras. Evidência: inventário de transferências, referências de avaliação jurídica, mecanismos contratuais quando aplicáveis, registros de localização e decisões de aprovação. Reavaliar após mudanças de fornecedor, local, lei ou modelo de acesso.

Capítulo 23 — Interface de Incidentes e Violações

Integrar privacidade à triagem de incidentes, preservação de evidências, análise de impacto, avaliação jurídica/regulatória, avaliação de impacto aos indivíduos, decisões de notificação e remediação pós-incidente. Evidência: registros de incidentes, decisões, cronogramas, avaliações de notificação, análise de causa-raiz e ações corretivas. Executar exercícios de mesa pelo menos anualmente.

Capítulo 24 — Monitoramento e Efetividade dos Controles

Definir indicadores de operação de controles, tendências de risco, desempenho de solicitações, incidentes, reclamações, exceções, achados de terceiros, inventários desatualizados e envelhecimento de remediações. Evidência: painéis, relatórios de exceção, análises de tendência e registros de ação. Estabelecer limites que acionem escalonamento e reavaliação.

Capítulo 25 — Métricas de Privacidade e Relatórios Gerenciais

Usar métricas que apoiem decisões, não contagens sem utilidade. Definir responsável, fórmula, sistema-fonte, frequência, limite, meta, público e ação para cada métrica. Evidência: dicionário de métricas, painéis, conciliações de fontes e relatórios gerenciais. Validar periodicamente a qualidade dos dados e se as métricas realmente orientam decisões.

Capítulo 26 — Revisão Interna e Asseguração

Planejar revisões baseadas em risco sobre governança, inventários, avaliações, engenharia, solicitações, retenção, fornecedores, incidentes e qualidade de evidência. Manter independência do revisor proporcional ao risco. Evidência: plano de revisão, papéis de trabalho, amostras, achados, respostas da administração e validação de fechamento. Repetir testes após remediação material.

Capítulo 27 — Ação Corretiva e Remediação

Registrar achados e falhas com severidade, causa-raiz, responsável, prazo, salvaguardas provisórias, evidência de correção e validação de fechamento. Evidência: registro de remediação, tickets, resultados de validação e aceitação de risco se houver extensão. Escalonar itens de alto risco vencidos conforme limites de governança.

Capítulo 28 — Exceções e Aceitação de Risco

Exigir justificativa documentada, escopo, risco, medidas compensatórias, responsável, aprovador, vencimento e reavaliação. Evidência: registro de exceções, aprovações, testes de controles compensatórios e alertas de vencimento. Proibir exceções indefinidas ou renovadas automaticamente sem reavaliação explícita.

Capítulo 29 — Treinamento, Conscientização e Competência por Função

Definir conscientização básica mais treinamento específico para privacidade, jurídico, engenharia, produto, RH, compras, segurança, suporte e executivos. Evidência: currículos, registros de conclusão, avaliações, mapeamento por função e remediação para falhas. Revisar conteúdo após mudanças materiais de política, regulação, tecnologia ou incidentes.

Capítulo 30 — Arquitetura de Evidência, Caminhos de Maturidade e Planejamento de Implementação

Manter repositório governado e modelo de rastreabilidade conectando decisões de risco, controles, procedimentos, sistemas, responsáveis, testes, achados e remediação. Usar caminhos Essencial, Estruturado e Avançado para sequenciar a implementação conforme risco e capacidade. Evidência: matriz controle/evidência, roadmap, avaliação de maturidade, mapa de dependências e aprovações gerenciais.

Capítulo 31 — Gatilhos de Mudança e Reavaliação do Framework

Definir gatilhos de reavaliação: mudanças legais/regulatórias, atualizações do NIST, incidentes, aquisições, novas jurisdições, novos usos de IA/analytics, mudanças relevantes de fornecedor, modelos de negócio e falhas repetidas. Evidência: registro de monitoramento de mudanças, verificação de fontes, análise de impacto e decisões controladas. A publicação final do PF 1.1 exige conciliação explícita antes de qualquer congelamento que declare alinhamento com essa versão.

Capítulo 32 — Publicação, Localização, Proveniência e Reavaliação

Congelar a fonte inglesa controlada somente após QA de fonte/copyright/semântica confirmar o escopo PF 1.0 e o tratamento não normativo do rascunho PF 1.1. Derivar es-419 e pt-BR somente dessa identidade exata. Exigir paridade estrutural e semântica trilingue, geração DOCX/PDF, QA de renderização e acessibilidade, vinculação SHA-256, manifesto de proveniência, controles de segurança de workflows, armazenamento durável em main, QA exata do head, verificação da ordem do predecessor e reconciliação final de catálogo/registro antes da publicação.

Lista final de aceitação da fonte controlada

Antes da publicação verificar:

- presença e ordem dos 32 capítulos;
- PF 1.0 como linha de base estável explícita;
- ausência de representação do rascunho PF 1.1 como final ou vinculante;
- preservação do caráter voluntário do framework do NIST;
- diferenciação entre obrigações legais e orientação do framework;
- conceitos de operação responsável, evidência, revisão/teste, remediação e reavaliação em cada capítulo;
- ausência de reprodução de texto protegido de terceiros;
- identidade da fonte congelada correta;
- estado de publicação bloqueado até concluir todos os gates artifact-first.